VOLUME 3: SOC DETECTION TESTS AND ANALYST RUNBOOK

PHASE 7: LIVE THREAT SIMULATION & ACCESS ACCOUNTABILITY

Testing Failed Local Authentication

- **Test:** On “CORP-CL-01”, I used “su” to enter five incorrect passwords for the local “corp-user” account. I then tried to switch to a non-existent account named “rogue-attacker” as a separate test. Both actions took place in the Ubuntu workstation’s terminal.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.15 (Logging); NIST SP 800-53 Rev. 5 AU-2 (Event Logging).
- **Verification search (SPL):**
  index=main host=CORP-CL-01 "authentication failure"

Explanation:
I wanted to check that failed local authentication attempts were reaching Splunk from the Linux workstation. I made the incorrect password attempts using “su”, tried a username that did not exist, and searched the central index for authentication failures from “CORP-CL-01”. I found matching events in Splunk, confirming that I could investigate these local attempts from the separate logging server. This gave me a known set of events for checking the collection pipeline before I built an alert.

Tracking a Successful Privileged Command

- **Test:** While “corp-user” still belonged to the “sudo” group on “CORP-CL-01”, I ran “sudo cat /etc/shadow”. The command succeeded, showing that this everyday account could use administrative permissions to read a file containing password hashes.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.2 (Privileged access rights) and A.8.15 (Logging); NIST SP 800-53 Rev. 5 AU-2 (Event Logging).
- **Verification search (SPL):**
  index=main host=CORP-CL-01 "COMMAND=/usr/bin/cat /etc/shadow"

Explanation:
I wanted to check whether Splunk recorded the use of an administrative command on the Linux workstation. I ran the command as "corp-user" and found its command record in the central logs. The test showed that I could investigate this privileged action from the separate Splunk server. It also revealed an access-control issue: an account intended for everyday use still had "sudo" permissions. I addressed that permission in the next test.

Correcting the Workstation's sudo Permissions

- **Configuration change and test:** The successful "/etc/shadow" test showed that "corp-user", my everyday account on "CORP-CL-01", still belonged to the administrative "sudo" group. I removed that membership with "sudo deluser corp-user sudo", started a fresh "corp-user" session using "su - corp-user", and repeated "sudo cat /etc/shadow". This time the command was denied before the file could be read. I also tested administrative commands involving "ip" and "shutdown" and checked their rejection records.
- **Relevant security controls:** UK Cyber Essentials User Access Control; ISO/IEC 27001:2022 Annex A.8.2 (Privileged access rights); NIST SP 800-53 Rev. 5 AC-6 (Least Privilege).

Explanation:
The first "/etc/shadow" test exposed a permission I had not intended to give my everyday account. After removing "corp-user" from the "sudo" group, I started a fresh session and ran the command again to check the effect of the change. Ubuntu denied it, and I found the denial in Splunk. The additional "ip" and "shutdown" attempts let me check the same restriction against other administrative actions. This gave me both a working access-control change and records I could investigate from the central logging server.

Reviewing Time Settings for Log Investigation

- **Configuration review:** I checked the time displayed across the lab machines while preparing to compare events from the domain controller, Linux workstation and Splunk server. Where a Linux machine needed the local timezone adjusted, I used “sudo timedatectl set-timezone Europe/London”.
- **Relevant security control:** NIST SP 800-53 Rev. 5 AU-8 (Time Stamps).

Explanation:
Events from different machines are easier to investigate when I know how each system displays its time. I reviewed the lab’s time settings and set the Linux timezone to “Europe/London” where needed, so I could interpret displayed timestamps consistently while examining the logs. This was a timezone configuration change. Precise ordering of events across machines also depends on their clocks being synchronised to a time source, which is a separate check from setting the timezone.

Windows Security Event IDs: Analyst Reference

- **Purpose:** “CORP-DC-01” forwarded its Windows Security log to Splunk. I identified three Event IDs useful for reviewing authentication and account activity on the domain controller.
- **Controlled test:** I deliberately used an incorrect password in a sign-in attempt on “CORP-DC-01”.
- **Verification:** I searched the Windows Security events forwarded to Splunk and found the corresponding Event ID 4625. This confirmed that the failed sign-in was available for investigation from the central SIEM.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.15 (Logging) and NIST SP 800-53 Rev. 5 AU-2 (Event Logging).

Event ID	What it records	What I would examine
4624, Logon Type 3	A successful network logon.	The account, source address, time and other activity around the logon.
4625	A failed logon.	The account, source and failure details. “0xC000006A” can indicate an incorrect password; “0xC0000234” indicates an account lockout.
4720	Creation of a user account.	Who created it, which account was created and whether the change was authorised.

Explanation:
On the Linux workstation, I could search authentication messages in “/var/log/auth.log”. Windows records comparable identity activity as numbered Security events. I used the three Event IDs above as an investigation reference, then tested the failed-logon collection by entering an incorrect password on “CORP-DC-01”. Finding the resulting

4625 event in Splunk showed that I could retrieve a specific Windows authentication failure from the central logging server. When reviewing a similar event, I would examine its account, source, time and failure details before deciding what related activity to investigate.

PHASE 8: AUTOMATED SECURITY ANALYTICS, REAL-TIME ALERTING, & EXECUTIVE DASHBOARDS

Creating a Real-Time Alert for Denied Administrative Commands

- **Configuration:** I turned my manual search for denied “sudo” attempts on “CORP-CL-01” into a saved Splunk alert. I set it to monitor for new matching events in real time.
- **Alert configuration:**
    - **Title: “CRITICAL - Unauthorized Privilege Escalation Attempt Detected”**
    - **Search: index=main host=CORP-CL-01 "NOT in sudoers"**
    - **Trigger: Real-time, per result**
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.16 (Monitoring Activities) and NIST SP 800-53 Rev. 5 SI-4 (System Monitoring).

Explanation:
After confirming that I could find denied “sudo” attempts through a manual search, I wanted Splunk to recognise the same event without waiting for me to search for it. I saved the search as a real-time, per-result alert. When a matching event becomes available to the search, Splunk can trigger the alert for review. This gives an analyst a prompt to investigate the account and command involved; the alert alone does not establish why the attempt was made.

Validating the Alert with a Denied Command

- **Test:** After removing “corp-user” from the workstation’s “sudo” group, I signed in as that user and repeated “sudo cat /etc/shadow”. Ubuntu denied the command.
- **Verification:** I checked Splunk’s Activity - Triggered Alerts page and found that the saved alert had triggered on the resulting event.
- **Relevant security controls:** UK Cyber Essentials (User access control), ISO/IEC 27001:2022 Annex A.8.16 (Monitoring Activities) and NIST SP 800-53 Rev. 5 SI-4 (System Monitoring).

Explanation:
I had confirmed that the denied command appeared in a manual Splunk search, but I also needed to test the alert I had built from that search. I repeated the command under the restricted "corp-user" account, confirmed that Ubuntu blocked it, and then checked the Triggered Alerts page. Finding the alert there showed that the workstation had recorded the denial, the event had reached Splunk and the saved rule had matched it. This completed my test of the alert from the attempted command through to the analyst's view.

SOC Tier 1 Procedure for Reviewing the Alert

- ***Purpose:*** *I wrote a simulated procedure for an analyst responding to the denied "sudo" alert. It sets out how to check the event, decide whether it needs further investigation and record the outcome.*
- ***Relevant security controls:*** *ISO/IEC 27001:2022 Annex A.5.25 (Assessment and Decision on Information Security Events) and A.5.26 (Response to Information Security Incidents); NIST SP 800-53 Rev. 5 IR-4 (Incident Handling).*

Analyst steps:

1. ***Verify the event:*** *Search "index=main host=CORP-CL-01 "sudo"" and inspect the account, command and event time. Check whether the activity matches an authorised test or maintenance task.*
2. ***Assess the surrounding activity:*** *Look for repeated denials, other unusual commands or related authentication failures. Record the evidence and the reason for the initial assessment.*
3. ***Respond according to the findings:*** *If the event was an authorised test, document and close it. If the evidence suggests unauthorised activity, escalate it for investigation. Isolating the workstation would be a containment decision if the investigation justified it, rather than an automatic response to one denied command.*

Explanation:
Creating an alert gave me a way to find a denied command; I also wanted a repeatable way to decide what to do with it. I wrote this procedure so an analyst would first check the actual event and its context, then record a decision before taking further action. My lab test was authorised and the command was blocked. The procedure describes how I would handle a similar alert in a SOC; it does not claim that I isolated the workstation or opened a real incident.

Building the SOC Dashboard

- **Dashboard configuration:** I built a Splunk dashboard titled **“Apex Corporation - Master Security Operations Centre (SOC) Dashboard”.** I used an XML layout, added a time range picker and displayed event counts by host as bar and pie charts.
- **Splunk search (SPL):** index=main | stats count by host
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.16 (Monitoring Activities) and NIST SP 800-53 Rev. 5 SI-4 (System Monitoring).

Illustrative dashboard layout:

Area	What I displayed or reviewed
Time range	**A selectable period, such as the last 24 hours.**
Host activity	**Bar and pie charts comparing event counts from “CORP-DC-01” and “CORP-CL-01”.**
Alert review	**Denied “sudo” alerts reviewed separately in Splunk’s Activity → Triggered Alerts page.**

Explanation:
My Windows domain controller and Ubuntu workstation were both sending events to Splunk, but comparing their activity through separate searches was cumbersome. I built the dashboard to show how many events came from each host within a selected time period. The charts gave me a quick way to compare the two feeds and notice if one host stopped appearing or its event volume changed unexpectedly. I could then open the underlying events to investigate. Together with the alert I had tested, the dashboard gave me a practical starting point for monitoring the lab from one place.

Planning Splunk Log Retention

- **Storage review:** After encountering the Splunk disk space warning earlier in the lab, I researched how Splunk moves indexed events through its **hot, warm, cold and frozen** bucket stages. This helped me consider how long logs should remain searchable and how their growth would affect the server's storage.
- **Relevant security controls:** ISO/IEC 27001:2022 Annex A.8.15 (Logging) and A.8.6 (Capacity Management); UK GDPR Article 5(1)(e) (Storage Limitation).

Bucket stage	What happens to the data
Hot	Splunk writes new events to an active bucket. The events are searchable.
Warm	Splunk has closed the bucket to new events, but its contents remain searchable.
Cold	Older buckets remain searchable and can be held in a separate storage location.
Frozen	The bucket leaves the searchable index. Splunk deletes it by default unless archiving has been configured.

Explanation:
Lowering Splunk's minimum free space threshold allowed my lab to resume collecting logs, but it did not solve the underlying storage limit. I studied the bucket lifecycle to understand how a longer-running SIEM would retain useful investigation records without allowing its index to grow indefinitely. A retention policy would need a defined period based on the purpose of the logs, the available storage and any applicable obligations. I would record that period and decide whether older data should be deleted or archived before applying the policy to an operational system.